

GRC102 — WEEK 1 PRACTICAL LABORATORY

Information Security Governance in Action

EVIDENCE BUNDLE 1

Governance Blueprint

Current-State Gap Assessment · Proposed Governance Structure · RACI Matrix · Governance Rationale

GlobalHealth Connect (GHC)

Executive Governance Simulation

Prepared by: Oluwatosin Olajubu

September 2026

1. Introduction

GlobalHealth Connect (GHC) is a mid-sized health-technology organisation providing cloud-based patient-management systems to healthcare organisations. Rapid growth, two acquisitions and a recently contained data-leakage near-miss have exposed weaknesses in GHC's current ad-hoc approach to information security governance. This Governance Blueprint sets out the current-state gaps, the proposed governance structure, the accountability model (RACI) and the rationale supporting the recommended design.

1.1 Current-State Governance Gap Assessment

GHC's current information security governance model contains several significant weaknesses across leadership, oversight, risk management and cross-functional coordination. These are summarised below.

Governance Area	Current-State Gap	Governance Risk
Leadership and Accountability	Security responsibilities are not formally defined across the organisation.	Individuals may assume others are responsible for security decisions and outcomes.
Security Ownership	The IT Manager performs some security activities, but there is no dedicated governance leadership function.	Operational security activities may take priority over strategic risk management and oversight.
Board Oversight	There is no clear evidence of structured security reporting to the Board.	The Board may lack sufficient visibility of material cyber risks and governance performance.
Risk Management	Security decisions appear reactive rather than based on a formal risk management process.	Emerging threats and business risks may not be identified or treated consistently.
Policy Governance	Policies and security expectations are not clearly governed across the organisation.	Inconsistent implementation may occur across departments and acquired businesses.
Cross-Functional Coordination	Security decisions may be handled independently by IT, Development, Compliance and business functions.	Conflicting priorities may delay decisions or create inconsistent controls.
Incident Governance	Following the data-leakage near-miss, the need for clearer escalation and accountability is evident.	Delays or confusion during security incidents could increase business and regulatory impact.
Third-Party and Acquisition Governance	Rapid growth and acquisitions may introduce systems, people and processes with different security practices.	Security gaps may remain unidentified during integration.

Key Governance Gaps

The most significant weakness is the absence of a clearly defined governance structure separating strategic oversight, executive accountability and operational responsibility.

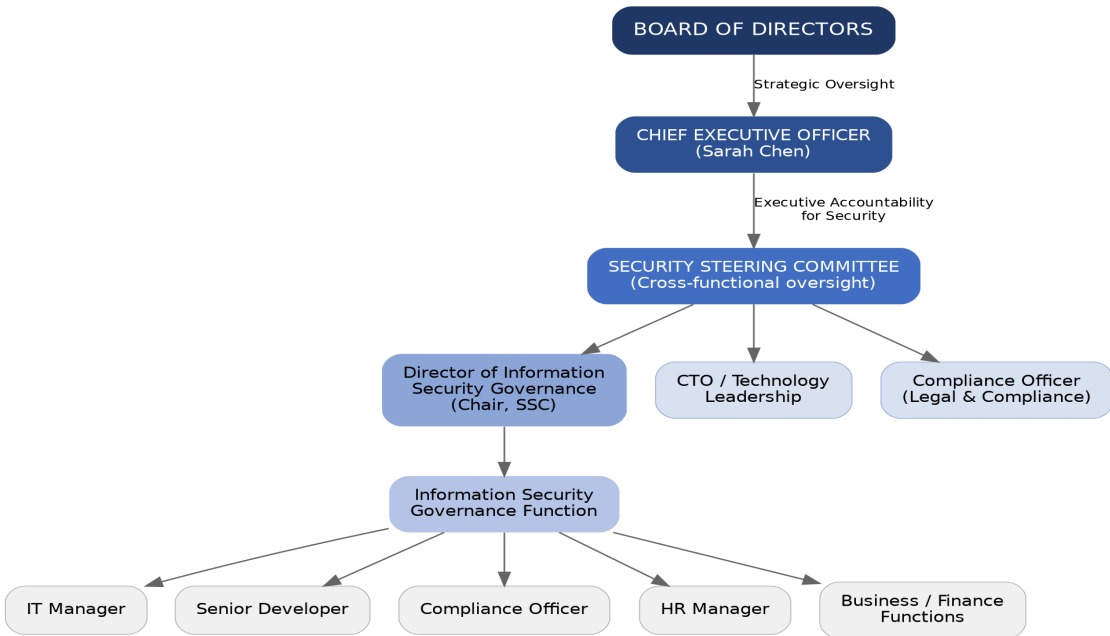
Currently, security activities appear to be concentrated primarily within IT Operations. This creates a risk that information security is viewed as an IT issue rather than an enterprise-wide business responsibility. Security governance should involve executive management, technology, compliance, human resources, finance and the Board.

Another major gap is unclear accountability. Although different stakeholders perform activities related to security, there is no formal model defining who is responsible for performing activities and who is ultimately accountable for decisions.

Finally, the current reactive approach to risk management means GHC may be responding to incidents rather than proactively identifying and managing risks before they affect the organisation.

1.2 Proposed Information Security Governance Structure

The proposed structure introduces clear lines of accountability and reporting, separating Board-level strategic oversight, executive accountability, cross-functional steering and operational delivery.



Proposed Reporting Relationships

- The Board provides strategic oversight and receives regular reports on information security risks, governance performance and material incidents.
- The CEO is accountable for ensuring that information security governance supports GHC's strategic objectives.
- The Director of Information Security Governance is responsible for coordinating the information security governance programme, managing governance processes, reporting risks and escalating significant issues.
- The Security Steering Committee provides cross-functional oversight and ensures that security decisions consider business, technology, compliance and operational requirements.
- Operational teams remain responsible for implementing security requirements within their areas of responsibility.

1.3 RACI Matrix

The RACI matrix below defines accountability for eight key information security governance activities, covering policy approval, risk oversight, incident planning, awareness, compliance, Board reporting and investment decisions.

Governance Activity	Boar d	CE O	Dir. ISG	CT O	IT Mgr	Compl. Officer	HR Mgr
Approve Information Security Policy	A	C	R	C	C	C	I
Review Enterprise Security Risks	A	A	R	C	C	C	I
Develop Security Policies and Standards	I	I	A/R	C	C	C	C
Incident Response Planning	I	A	A	C	R	C	C
Security Awareness Programme	I	I	A	I	C	C	R
Regulatory Compliance Monitoring	I	A	C	I	C	R	C
Security Metrics and Board Reporting	A	C	R	C	C	C	I
Security Investment Prioritisation	A	A	R	C	C	C	I

R Responsible — performs the work	A Accountable — owns the outcome and decision	C Consulted — provides input before a decision	I Informed — kept up to date after a decision
--	--	---	--

1.4 Governance Rationale

The proposed governance structure improves accountability by clearly distinguishing between oversight, accountability and operational responsibility. The Board provides strategic oversight, executive management ensures alignment with organisational objectives and operational teams implement security controls.

Transparency is improved through formal reporting structures and the Security Steering Committee. Significant risks, incidents and performance issues can be escalated through defined channels rather than remaining isolated within technical teams.

The structure also supports business alignment. GHC's strategic objectives include market expansion, operational efficiency, customer trust, innovation and regulatory excellence. Security governance must therefore support these objectives rather than operate independently from them.

Finally, the proposed model improves risk management by introducing regular risk review, defined decision-making authority and cross-functional participation.